IT5054 – INFORMATION SECURITY

COMPREHENSIVE QUESTION BANK & SELF-ASSESSMENT COMPANION
Unit V (Authentication, Passwords, Biometrics) & Unit VI (CAPTCHA, Firewalls, IDS)

Total Questions: 74 MCQs | **Target Exam:** Semester Examination - 2 | **Format:** 4 Options + Verified Key & Detailed Explanation

UNIT V: AUTHENTICATION METHODS, PASSWORDS & BIOMETRICS

Q1. What is the fundamental purpose of the authentication process in information security? [Authentication Fundamentals | Easy]

A) Verifying that an entity (user, device, or service) is genuinely who or what it claims to be

B) Determining the permissions and resources an entity is allowed to access

C) Encrypting all transmitted data packets using symmetric ciphers

D) Creating permanent off-site backups of user profile directories

✓ **Correct Answer: Verifying that an entity (user, device, or service) is genuinely who or what it claims to be**
Explanation: Authentication answers 'Can you prove your claimed identity?', while authorization determines permissions after identity is confirmed.

Q2. How does authentication strictly differ from authorization in system security? [Authentication Fundamentals | Easy]

A) Authentication verifies the claimed identity; authorization decides what an authenticated entity is permitted to do

B) Authentication assigns file system permissions; authorization checks passwords

C) Authentication is only used for hardware devices; authorization is for human users

D) Both terms are interchangeable and describe identical cryptographic functions

✓ **Correct Answer: Authentication verifies the claimed identity; authorization decides what an authenticated entity is permitted to do**
Explanation: A username identifies an account, a password authenticates the user, and permissions (authorization) control resource access.

Q3. In an online login workflow, what role does submitting a username perform? [Authentication Fundamentals | Easy]

A) Identification (claiming an identity or account name)

B) Authorization (granting administrator rights immediately)

C) Encryption (scrambling the network socket)

D) Non-repudiation (legally signing a digital certificate)

✓ **Correct Answer: Identification (claiming an identity or account name)**
Explanation: Entering a username establishes the claimed identity; entering the correct password provides the authentication proof.

Q4. What are the three classical fundamental categories of authentication factors? [Authentication Factors | Easy]

A) Something you know, Something you have, and Something you are

B) Something you read, Something you write, and Something you execute

C) Username, Password, and IP address

D) Private key, Public key, and Symmetric key

✓ **Correct Answer: Something you know, Something you have, and Something you are**
Explanation: The three recognized primary authentication factors are knowledge (know), possession (have), and inherence/biometric (are).

Q5. Which of the following credentials belongs to the 'Something you know' factor category? [Authentication Factors | Easy]

A) A passphrase, password, or numeric PIN

B) A physical USB FIDO2 hardware token

C) A capacitive fingerprint scan

D) A registered smartphone receiving SMS

✓ **Correct Answer: A passphrase, password, or numeric PIN**
Explanation: Knowledge factors encompass information that a user is expected to memorize and recall, such as passwords, passphrases, and PINs.

Q6. Which of the following authenticators belongs to the 'Something you have' factor category? [Authentication Factors | Easy]

A) A physical hardware security key, smart card, or authenticator app token

B) A secret memorized security question answer

C) An iris scan pattern

D) A user's high school mascot name

✓ **Correct Answer: A physical hardware security key, smart card, or authenticator app token**

Explanation: Possession factors rely on the user holding or controlling a tangible device or cryptographic hardware key.

Q7. Which of the following authenticators belongs to the 'Something you are' factor category? [Authentication Factors | Easy]

A) A biological fingerprint, retinal scan, or facial geometric map

B) A 6-digit TOTP code generated by Google Authenticator

C) An employee magnetic RFID badge

D) A 16-character alphanumeric passphrase

✓ **Correct Answer: A biological fingerprint, retinal scan, or facial geometric map**

Explanation: Inherence factors are based on measurable human biological or behavioral physical characteristics.

Q8. What is an inherent security limitation of the 'Something you know' factor category? [Authentication Factors | Medium]

A) Knowledge secrets can be guessed, phished, shoulder-surfed, reused, or disclosed

B) They require expensive physical sensors to read

C) They cannot be used across remote network connections

D) They are permanently tied to a user's biological anatomy

✓ **Correct Answer: Knowledge secrets can be guessed, phished, shoulder-surfed, reused, or disclosed**

Explanation: Passwords and PINs are vulnerable to social engineering, interception, brute force, and credential reuse across websites.

Q9. What is an inherent operational challenge associated with the 'Something you have' factor category? [Authentication Factors | Medium]

A) Physical tokens or smartphones can be lost, damaged, stolen, or have dead batteries, requiring recovery workflows

B) They are mathematically easy to guess through brute-force dictionaries

C) They can never be used in enterprise multi-factor authentication

D) They require specialized optical fingerprint scanners

✓ **Correct Answer: Physical tokens or smartphones can be lost, damaged, stolen, or have dead batteries, requiring recovery workflows**

Explanation: Possession tokens require reliable backup and account recovery procedures in case the user misplaces the physical device.

Q10. Which password characteristic provides the greatest mathematical resistance against modern offline brute-force attacks? [Passwords & Verification | Medium]

A) Password length (entropy increases exponentially with length)

B) Changing the password every 7 days to a predictable variation

C) Using simple common dictionary words with the first letter capitalized

D) Limiting the password to strictly numeric characters

✓ **Correct Answer: Password length (entropy increases exponentially with length)**

Explanation: Password length dramatically increases the search space (N^L), making long passphrases far superior to short complex passwords.

Q11. Why is password reuse across multiple external web services considered a critical security vulnerability? [Passwords & Verification | Medium]

A) A breach at one compromised website exposes credentials that attackers can use on all other services

B) It causes database collisions in the server's cryptographic libraries

C) Web browsers automatically delete passwords used more than once

D) It violates transport layer protocol standards

✓ **Correct Answer: A breach at one compromised website exposes credentials that attackers can use on all other services**

Explanation: Credential stuffing attacks weaponize breached password dumps from third-party sites against banking and email portals.

Q12. How should user passwords be stored inside an enterprise production database? [Passwords & Verification | Hard]

A) As a salted cryptographic hash computed with an intentionally slow Key Derivation Function (KDF)

B) In plaintext inside an encrypted database column

C) Encrypted with reversible two-way AES symmetric encryption

D) Obfuscated using Base64 encoding

✓ **Correct Answer: As a salted cryptographic hash computed with an intentionally slow Key Derivation Function (KDF)**

Explanation: Servers must never store plaintext passwords; only irreversible, salted, computationally expensive verifiers should be retained.

Q13. What is a cryptographic 'Salt' in the context of password verification and storage? [Passwords & Verification | Medium]

A) A unique, cryptographically random string generated and stored alongside each user's password verifier

B) A secret global key that must be hidden inside the server's CPU firmware

C) A reversible decryption algorithm for password recovery

D) A public key used to digitally sign user cookies

✓ **Correct Answer: A unique, cryptographically random string generated and stored alongside each user's password verifier**

Explanation: A salt ensures that two users with identical passwords have completely different stored hashes, defeating precomputed rainbow tables.

Q14. Does a cryptographic salt need to be kept secret from database administrators or attackers? [Passwords & Verification | Medium]

A) No, the salt is not a secret key; it is stored openly alongside the hash in the database

B) Yes, if an attacker learns the salt, all password hashes are instantly reversed

C) Yes, salts must be stored in hardware security modules (HSM) only

D) Only during the initial enrollment phase

✓ **Correct Answer: No, the salt is not a secret key; it is stored openly alongside the hash in the database**

Explanation: The security of salting comes from its uniqueness per user, not from keeping the salt string hidden.

Q15. What primary attack vector is effectively neutralized by adding a unique salt to each password before hashing? [Passwords & Verification | Medium]

A) Precomputed lookup attacks such as Rainbow Table attacks

B) Online SQL injection attacks against the login form

C) Man-in-the-middle packet sniffing on local Wi-Fi

D) Distributed Denial of Service (DDoS) bandwidth floods

✓ **Correct Answer: Precomputed lookup attacks such as Rainbow Table attacks**

Explanation: Rainbow tables precompute hashes for millions of passwords; a unique salt forces an attacker to compute a brand-new table for every single account.

Q16. Which of the following algorithms are recommended modern Key Derivation Functions (KDFs) specifically designed for secure password hashing? [Passwords & Verification | Hard]

A) Argon2, bcrypt, and scrypt

B) MD5, SHA-1, and CRC32

C) DES, 3DES, and RC4

D) RSA, Diffie-Hellman, and ECC

✓ **Correct Answer: Argon2, bcrypt, and scrypt**

Explanation: Argon2, bcrypt, and scrypt are intentionally memory-hard and computationally expensive, slowing down GPU and ASIC brute-force cracking.

Q17. Why are general-purpose cryptographic hash functions like SHA-256 or MD5 unsuited for password storage without specialized KDF stretching? [Passwords & Verification | Hard]

A) They are designed to be fast, enabling attackers with modern GPUs to compute billions of guesses per second

B) They produce 64-bit outputs that collide frequently

C) They can only hash strings shorter than 8 characters

D) They require paid proprietary commercial licensing

✓ **Correct Answer: They are designed to be fast, enabling attackers with modern GPUs to compute billions of guesses per second**

Explanation: Fast hash functions allow massive offline dictionary cracking; password KDFs introduce deliberate configurable work factors.

Q18. What occurs during an online 'Brute-Force' attack against a web authentication endpoint? [Password Attacks | Medium]

A) An automated tool systematically submits thousands or millions of possible character combinations against an account

B) An attacker sends spoofed ARP responses to redirect network traffic

C) A rogue router modifies DNS records to point to a malicious server

D) An attacker steals backup tapes from a data center

✓ Correct Answer: An automated tool systematically submits thousands or millions of possible character combinations against an account

Explanation: Online brute force attempts combinations directly against the authentication API until the correct password matches.

Q19. What is the defining characteristic of a 'Credential Stuffing' attack? [Password Attacks | Medium]

A) Automated injection of stolen username/password pairs breached from one site against many unrelated websites

B) Testing thousands of passwords against a single administrative account until it locks

C) Intercepting keystrokes using a hardware dongle plugged into a keyboard

D) Guessing user security questions using public social media posts

✓ Correct Answer: Automated injection of stolen username/password pairs breached from one site against many unrelated websites

Explanation: Credential stuffing exploits user credential reuse across banking, retail, and corporate portals using leaked breach databases.

Q20. How does a 'Password Spraying' attack differ from traditional brute-force password guessing? [Password Attacks | Hard]

A) Password spraying tries a few common passwords across many accounts to evade account lockout thresholds

B) Password spraying tests millions of passwords against a single high-value account

C) Password spraying uses physical radio frequency transmitters to jam Wi-Fi

D) Password spraying permanently corrupts the database salt values

✓ Correct Answer: Password spraying tries a few common passwords across many accounts to evade account lockout thresholds

Explanation: By attempting only 1 or 2 guesses (e.g. 'Winter2026!') per account, password spraying stays beneath account lockout triggers.

Q21. What is the mechanism of a 'Phishing' attack against user credentials? [Password Attacks | Easy]

A) Deceptive communication (such as fraudulent emails or lookalike websites) that tricks users into divulging secrets

B) Using supercomputers to calculate discrete logarithms of public keys

C) Overloading web servers with SYN packets to exhaust connection queues

D) Physically intercepting underwater fiber cables

✓ Correct Answer: Deceptive communication (such as fraudulent emails or lookalike websites) that tricks users into divulging secrets

Explanation: Phishing relies on social engineering and deceptive user interfaces to harvest credentials directly from legitimate users.

Q22. What defensive mechanism provides the strongest protection against deceptive credential phishing websites? [Password Attacks | Hard]

A) FIDO2 / WebAuthn hardware security keys with cryptographic origin binding

B) Requiring users to change passwords every 30 days

C) Using 6-digit SMS text message verification codes

D) Adding a CAPTCHA to the registration page

✓ Correct Answer: FIDO2 / WebAuthn hardware security keys with cryptographic origin binding

Explanation: Hardware security keys bind cryptographic responses to the exact browser domain origin, making it impossible for lookalike phishing sites to replay responses.

Q23. What defensive control effectively stops automated online brute-force guessing against user login forms?
[Password Attacks | Medium]

A) Rate limiting, exponential backoff, IP reputation filtering, and risk-based CAPTCHA challenges

B) Disabling HTTPS encryption on the login page

C) Allowing unlimited simultaneous login attempts from any IP

D) Storing passwords in MD5 format

✓ Correct Answer: Rate limiting, exponential backoff, IP reputation filtering, and risk-based CAPTCHA challenges
Explanation: Rate limiting restricts the frequency of login attempts, drastically increasing the time required for brute-force tools.

Q24. How does biometric authentication typically verify an individual? **[Biometrics | Medium]**

A) By capturing a biological sample, extracting distinctive mathematical features, and comparing them to an enrolled template

B) By storing raw high-resolution uncompressed photo images in the clear on a central server

C) By transmitting human DNA samples across TCP port 443

D) By asking the user to solve complex differential equations

✓ Correct Answer: By capturing a biological sample, extracting distinctive mathematical features, and comparing them to an enrolled template
Explanation: Biometrics extract feature vectors (minutiae points, iris patterns) and compare them probabilistically against an enrolled template.

Q25. What does the False Acceptance Rate (FAR) metric measure in a biometric authentication system? **[Biometrics | Hard]**

A) The probability that an unauthorized impostor is incorrectly accepted as an authorized user

B) The probability that a genuine authorized user is incorrectly rejected

C) The percentage of times a fingerprint sensor gets physically dirty

D) The time taken by the server to compute a cryptographic hash

✓ Correct Answer: The probability that an unauthorized impostor is incorrectly accepted as an authorized user
Explanation: FAR (Type II error) indicates security risk: a lower FAR means fewer unauthorized entities are mistakenly granted access.

Q26. What does the False Rejection Rate (FRR) metric measure in a biometric authentication system? **[Biometrics | Hard]**

A) The probability that a legitimate authorized user is incorrectly rejected by the system

B) The probability that an impostor gains administrative privileges

C) The rate at which passwords expire in an Active Directory forest

D) The frequency of server power supply reboots

✓ Correct Answer: The probability that a legitimate authorized user is incorrectly rejected by the system
Explanation: FRR (Type I error) indicates usability: a higher FRR frustrates genuine users who are denied access despite being legitimate.

Q27. What happens in a biometric system when administrators adjust the sensitivity decision threshold to make it strictly tighter? **[Biometrics | Hard]**

A) FAR decreases (higher security) while FRR increases (reduced user convenience)

B) Both FAR and FRR decrease simultaneously to zero

C) FRR decreases while FAR increases to 100%

D) The biometric system switches automatically to plain text passwords

✓ Correct Answer: FAR decreases (higher security) while FRR increases (reduced user convenience)
Explanation: Tuning a biometric system is an inherent trade-off: tightening the match criteria reduces false acceptances but increases false rejections.

Q28. What is the Crossover Error Rate (CER) or Equal Error Rate (EER) in biometric evaluation? **[Biometrics | Hard]**

A) The point on the operating characteristic curve where the False Acceptance Rate equals the False Rejection Rate (FAR = FRR)

B) The rate of physical sensor component failures per year

C) The speed of network packet transmission across biometric sensors

D) The difference between password length and biometric template size

✓ Correct Answer: The point on the operating characteristic curve where the False Acceptance Rate equals the False Rejection Rate (FAR = FRR)
Explanation: EER/CER is the standard benchmark metric used to compare the overall accuracy of different biometric systems (lower EER = better accuracy).

Q29. What is a critical fundamental vulnerability of biometric data compared to knowledge-based passwords?
[Biometrics | Hard]

A) Biometrics cannot be revoked or changed if compromised (a user cannot change their physical face or fingerprints)

B) Biometrics are impossible to read using modern electronic devices

C) Biometrics require users to memorize 30-digit numbers

D) Biometric templates expire automatically after 24 hours

✓ Correct Answer: Biometrics cannot be revoked or changed if compromised (a user cannot change their physical face or fingerprints)
Explanation: If a biometric template or high-res photo is stolen, the user cannot simply reset their biological iris or fingerprint.

Q30. Which of the following combinations represents true Multi-Factor Authentication (MFA)? **[Multi-Factor Authentication | Medium]**

A) Entering a memorized password (know) followed by inserting a physical USB security key (have)

B) Entering a password (know) followed by answering a security question (know)

C) Entering a numeric PIN (know) followed by entering a master password (know)

D) Scanning a fingerprint (are) followed by performing a facial recognition scan (are)

✓ Correct Answer: Entering a memorized password (know) followed by inserting a physical USB security key (have)
Explanation: True MFA requires two or more independent categories (e.g. know + have). Combining two items from the same category is single-factor multi-step.

UNIT VI: FIREWALLS & INTRUSION DETECTION

Q31. What is the complete full form of the acronym CAPTCHA? **[CAPTCHA | Easy]**

A) Completely Automated Public Turing test to tell Computers and Humans Apart

B) Computer Automated Protocol for Threat Containment and Human Authentication

C) Centralized Authorization Program To Check Human Access

D) Cryptographic Application Packet for Turing Channel Assessment

✓ Correct Answer: Completely Automated Public Turing test to tell Computers and Humans Apart
Explanation: CAPTCHA is an automated challenge-response test designed to ensure that user inputs are generated by a human rather than a bot.

Q32. What is the primary objective of deploying CAPTCHA on account creation and login forms? **[CAPTCHA | Medium]**

A) To prevent automated bot abuse, credential stuffing, scraping, and spam submissions

B) To verify the legal identity and physical home address of the user

C) To encrypt credit card numbers before saving to disk

D) To translate web pages into foreign languages

✓ Correct Answer: To prevent automated bot abuse, credential stuffing, scraping, and spam submissions
Explanation: CAPTCHA is an anti-automation rate-limiting defense; it distinguishes automated software from human users but does not authenticate identity.

Q33. Does solving a CAPTCHA successfully authenticate a user's personal identity? **[CAPTCHA | Medium]**

A) No, CAPTCHA confirms that the entity is likely a human, not who that human actually is

B) Yes, solving a CAPTCHA grants instant administrative rights

C) Yes, CAPTCHA is classified as a 'Something you are' biometric factor

D) Only if the CAPTCHA contains audio speech recognition

✓ Correct Answer: No, CAPTCHA confirms that the entity is likely a human, not who that human actually is
Explanation: CAPTCHA test verifies humanness, not identity. A human attacker can solve a CAPTCHA and still perform manual unauthorized attacks.

Q34. Which of the following is a common limitation or drawback of traditional distorted text/image CAPTCHAs?
[CAPTCHA | Medium]

A) They create accessibility barriers for visually impaired users and can often be solved by modern computer vision/AI models

B) They permanently consume 90% of router network bandwidth

C) They cause web browsers to crash if cookies are enabled

D) They only work on desktop operating systems

✓ Correct Answer: They create accessibility barriers for visually impaired users and can often be solved by modern computer vision/AI models
Explanation: Traditional visual CAPTCHAs degrade user experience, hinder accessibility, and are increasingly vulnerable to machine learning solvers.

Q35. What is the primary role of a Firewall in network security architecture? **[Firewall Fundamentals | Easy]**

A) To monitor, inspect, and filter incoming and outgoing network traffic according to an established security policy

B) To speed up physical internet bandwidth by compressing fiber optic signals

C) To scan hard drives for inactive duplicate files

D) To automatically reboot web servers when RAM exceeds 80%

✓ Correct Answer: To monitor, inspect, and filter incoming and outgoing network traffic according to an established security policy
Explanation: A firewall serves as a barrier between trusted internal networks and untrusted external networks (such as the Internet).

Q36. What is the default security posture known as 'Default Deny' (or implicit deny) in firewall configuration? **[Firewall Fundamentals | Medium]**

A) All traffic is blocked by default unless an explicit rule specifically permits it

B) All traffic is allowed unless an explicit rule blocks it

C) Traffic is allowed only during daytime hours

D) Traffic is permitted if the source IP is an odd number

✓ Correct Answer: All traffic is blocked by default unless an explicit rule specifically permits it
Explanation: Default Deny is the foundational best practice for firewalls: block everything by default and carve out minimal exceptions.

Q37. How does a Stateless Packet-Filtering Firewall make allow/deny decisions on passing network traffic? **[Firewall Classifications | Medium]**

A) By inspecting packet header fields (source/destination IP, source/destination port, protocol) in isolation without tracking session history

B) By analyzing user session state in an active dynamic memory state table

C) By decrypting TLS payload data and scanning for malware signatures

D) By looking up user fingerprints in an Active Directory database

✓ Correct Answer: By inspecting packet header fields (source/destination IP, source/destination port, protocol) in isolation without tracking session history
Explanation: Packet filters operate at OSI Layers 3 & 4, examining each individual packet independently against static header criteria.

Q38. What is the major vulnerability of a purely stateless packet-filtering firewall regarding TCP connections? **[Firewall Classifications | Hard]**

A) It cannot verify whether an inbound packet with the ACK bit set actually belongs to an established legitimate outbound connection

B) It cannot filter traffic by IP address

C) It requires 100 times more memory than stateful firewalls

D) It cannot operate on Ethernet networks

✓ Correct Answer: It cannot verify whether an inbound packet with the ACK bit set actually belongs to an established legitimate outbound connection
Explanation: Attackers can craft packets with fake ACK flags that easily bypass simple stateless packet filters that permit established incoming ACK packets.

Q39. What key architectural capability distinguishes a Stateful Inspection Firewall from a stateless packet filter? [Firewall Classifications | Hard]

A) It maintains a dynamic state table tracking active connections (e.g. TCP handshake stages, sequence numbers, timeouts)

B) It eliminates the need for IP addresses in network packets

C) It physically disconnects router cables when an error occurs

D) It operates strictly at the physical layer of the OSI model

✓ Correct Answer: It maintains a dynamic state table tracking active connections (e.g. TCP handshake stages, sequence numbers, timeouts)

Explanation: Stateful firewalls understand connection context: they allow return packets only if they match an active session initiated from inside.

Q40. How does an Application-Level Gateway (Proxy Firewall) inspect and control client-server traffic? [Firewall Classifications | Hard]

A) It acts as an intermediary, terminating the client's connection and establishing a separate connection to the server while inspecting application payloads

B) It forwards raw electrical signals without inspecting headers

C) It routes packets exclusively using RIP hop counts

D) It modifies the BIOS firmware on client laptops

✓ Correct Answer: It acts as an intermediary, terminating the client's connection and establishing a separate connection to the server while inspecting application payloads

Explanation: Application proxies operate at Layer 7, understanding protocol commands (like HTTP GET, FTP RETR) and hiding internal network IP addresses.

Q41. What is a Circuit-Level Gateway firewall, and at which OSI layer does it typically operate? [Firewall Classifications | Hard]

A) It validates the establishment of TCP/UDP sessions at the Transport Layer (Layer 4) without detailed inspection of individual application payloads

B) It inspects HTML code at the Application Layer (Layer 7)

C) It controls physical voltages at Layer 1

D) It manages MAC address tables on Layer 2 switches

✓ Correct Answer: It validates the establishment of TCP/UDP sessions at the Transport Layer (Layer 4) without detailed inspection of individual application payloads

Explanation: Circuit-level gateways (such as SOCKS proxies) control connection handshakes between trusted and untrusted hosts without full payload parsing.

Q42. What advanced capabilities characterize a Next-Generation Firewall (NGFW)? [Firewall Classifications | Hard]

A) Integrated deep packet inspection (DPI), application identification, integrated IDS/IPS, user identity awareness, and SSL/TLS decryption

B) Replacing all IP addresses with 128-bit MAC addresses

C) Operating completely without any software or rules

D) Eliminating the need for antivirus software on all endpoints

✓ Correct Answer: Integrated deep packet inspection (DPI), application identification, integrated IDS/IPS, user identity awareness, and SSL/TLS decryption

Explanation: NGFWs move beyond simple ports and IPs to recognize applications (e.g. distinguishing Skype from web browsing on port 443) and inspect encrypted traffic.

Q43. What is a Personal Firewall (or Host-Based Firewall)? [Personal Firewalls | Easy]

A) A software security application running directly on an individual host computer to control traffic to and from that specific device

B) A large hardware appliance rack-mounted at an Internet Service Provider (ISP)

C) A firewall installed exclusively on home microwave ovens

D) A physical padlock placed on a desktop computer case

✓ Correct Answer: A software security application running directly on an individual host computer to control traffic to and from that specific device

Explanation: Examples like Windows Defender Firewall protect endpoints from unauthorized network connections and control which local programs can access the network.

Q44. Why is a personal host-based firewall necessary even when an organization has a perimeter hardware firewall at its border? [Personal Firewalls | Medium]

A) It provides defense-in-depth, protecting devices against lateral attacks originating from inside the local network or untrusted Wi-Fi

B) Perimeter firewalls only inspect outgoing traffic, never inbound traffic

C) Personal firewalls speed up internet download speeds

D) Host firewalls generate public IP addresses for home routers

✓ Correct Answer: It provides defense-in-depth, protecting devices against lateral attacks originating from inside the local network or untrusted Wi-Fi

Explanation: If a laptop is connected to public Wi-Fi or malware compromises another computer on the internal LAN, the host firewall prevents lateral spread.

Q45. What is the primary operational difference between a Firewall and an Intrusion Detection System (IDS)? [Intrusion Detection Systems | Medium]

A) A firewall actively permits or blocks traffic based on policies; an IDS passively monitors traffic, identifies threats, and raises alerts

B) A firewall monitors audio files; an IDS monitors text files

C) An IDS replaces all network routers; a firewall replaces switches

D) There is no difference; they are two marketing names for identical hardware

✓ Correct Answer: A firewall actively permits or blocks traffic based on policies; an IDS passively monitors traffic, identifies threats, and raises alerts

Explanation: A firewall is an active gatekeeper (in-line filter), whereas a traditional IDS is a surveillance monitor (detects and notifies).

Q46. What is the difference between an Intrusion Detection System (IDS) and an Intrusion Prevention System (IPS)? [Intrusion Detection Systems | Medium]

A) An IDS detects and notifies administrators of attacks; an IPS sits in-line and actively blocks or drops malicious packets automatically

B) An IDS operates at Layer 7; an IPS operates only at Layer 1

C) An IDS requires no electricity; an IPS requires optical lasers

D) An IPS is for home computers; an IDS is for cloud databases only

✓ Correct Answer: An IDS detects and notifies administrators of attacks; an IPS sits in-line and actively blocks or drops malicious packets automatically

Explanation: An IDS raises alerts for human review; an IPS operates actively in-line and can drop packets or reset connections in real time.

Q47. What is a Network-based Intrusion Detection System (NIDS)? [Intrusion Detection Systems | Medium]

A) An IDS that monitors network traffic across an entire subnet by capturing packets from a SPAN mirror port or network tap

B) An antivirus agent installed on an individual smartphone

C) A firewall that filters email spam on mail servers

D) A software compiler that checks C++ source code

✓ Correct Answer: An IDS that monitors network traffic across an entire subnet by capturing packets from a SPAN mirror port or network tap

Explanation: NIDS (e.g. Snort, Zeek) inspects packets traversing network segments to detect port scans, buffer overflows, and malware communications.

Q48. What is a Host-based Intrusion Detection System (HIDS)? [Intrusion Detection Systems | Medium]

A) An IDS agent running on a specific host that analyzes local system logs, file integrity, process activity, and system calls

B) A router that forwards packets between Autonomous Systems

C) A satellite ground station monitoring radio waves

D) A physical badge reader on a server room door

✓ Correct Answer: An IDS agent running on a specific host that analyzes local system logs, file integrity, process activity, and system calls

Explanation: HIDS (e.g. OSSEC, Wazuh) monitors operating system events, unauthorized file modifications, and local privilege escalation attempts.

Q49. How does a Signature-Based (Knowledge-Based) Intrusion Detection System operate? [Detection Methodologies | Medium]

A) By comparing observed network traffic or system events against a database of known threat patterns, byte sequences, or exploit rules

B) By calculating mathematical standard deviations of normal daily bandwidth

C) By asking users to authenticate with biometrics

D) By encrypting all database files using RSA-2048

✓ Correct Answer: By comparing observed network traffic or system events against a database of known threat patterns, byte sequences, or exploit rules

Explanation: Signature detection is fast and highly accurate for known exploits (low false positives) but cannot detect novel zero-day attacks.

Q50. What is a primary limitation of signature-based intrusion detection systems? [Detection Methodologies | Medium]

A) They cannot detect previously unknown zero-day attacks or stealthily obfuscated variations of known exploits

B) They generate massive false positive alarms for normal network usage

C) They cannot run on high-speed Gigabit Ethernet networks

D) They require daily manual operating system reboots

✓ Correct Answer: They cannot detect previously unknown zero-day attacks or stealthily obfuscated variations of known exploits

Explanation: If an attack pattern has no matching signature in the IDS rules database, signature-based systems will fail to flag the malicious activity.

Q51. How does an Anomaly-Based (Behavior-Based) Intrusion Detection System operate? [Detection Methodologies | Hard]

A) By establishing a baseline of normal system/network activity and generating alerts when observed behavior deviates significantly from that baseline

B) By matching packet bytes to an exact list of virus signatures

C) By blocking all TCP traffic on port 80 and 443 permanently

D) By forcing users to re-enter passwords every 5 minutes

✓ Correct Answer: By establishing a baseline of normal system/network activity and generating alerts when observed behavior deviates significantly from that baseline

Explanation: Anomaly detection models normal patterns (traffic volume, protocols, login times) and flags unusual deviations, catching novel attacks.

Q52. What is a common operational challenge associated with anomaly-based intrusion detection systems? [Detection Methodologies | Hard]

A) High false positive rates caused by legitimate but unusual spikes in network activity or novel business tasks

B) Inability to detect zero-day exploits

C) Complete failure when connected to local area networks

D) High consumption of laser printer toner

✓ Correct Answer: High false positive rates caused by legitimate but unusual spikes in network activity or novel business tasks

Explanation: Whenever normal legitimate network behavior changes (e.g. software updates, heavy backups), anomaly systems frequently generate false alarms.

Q53. Why do modern Security Operations Centers (SOCs) widely deploy Hybrid Intrusion Detection Systems? [Detection Methodologies | Medium]

A) To combine the high precision of signature detection for known threats with the zero-day discovery capability of anomaly detection

B) To eliminate the requirement for trained human security analysts

C) To bypass the need for network firewalls

D) To avoid paying internet service provider bandwidth fees

✓ Correct Answer: To combine the high precision of signature detection for known threats with the zero-day discovery capability of anomaly detection

Explanation: Hybrid systems maximize detection effectiveness while balancing false positives and minimizing blind spots.

UNIT V: AUTHENTICATION METHODS, PASSWORDS & BIOMETRICS

Q54. A bank requires customers to enter a username, password, and then approve a notification prompt on their registered mobile banking app. What authentication mechanism is being enforced? [Authentication Scenarios | Easy]

A) Multi-Factor Authentication (MFA combining knowledge and possession factors)

B) Single-Factor Authentication with redundant knowledge prompts

C) Biometric Authorization without knowledge checks

D) Mutual Transport Layer TLS authentication

✓ **Correct Answer: Multi-Factor Authentication (MFA combining knowledge and possession factors)**

Explanation: The password satisfies 'Something you know' and the registered smartphone app satisfies 'Something you have', constituting true MFA.

Q55. An employee accesses a secure data center by entering a 4-digit PIN on a keypad and answering their mother's maiden name. Why is this NOT considered Multi-Factor Authentication? [Authentication Scenarios | Medium]

A) Both authenticators belong to the same factor category: 'Something you know'

B) PINs cannot be used in corporate data centers

C) Security questions are legally considered biometric factors

D) Data centers require iris scanners by international law

✓ **Correct Answer: Both authenticators belong to the same factor category: 'Something you know'**

Explanation: Using two knowledge factors (PIN + secret question) is multi-step single-factor authentication, not MFA.

Q56. A security administrator notices hundreds of failed login attempts for the username 'admin' from various IP addresses within seconds. What type of attack is most likely taking place? [Authentication Scenarios | Easy]

A) Online dictionary or brute-force attack targeting a single privileged account

B) Password spraying across the entire corporate domain

C) Passive eavesdropping on fiber cables

D) Cross-Site Scripting (XSS) attack on the homepage

✓ **Correct Answer: Online dictionary or brute-force attack targeting a single privileged account**

Explanation: Repeated rapid password attempts against a single specific account ('admin') indicate a targeted brute-force or dictionary guessing attack.

Q57. An attacker tests the password 'Company2026!' against 10,000 distinct employee usernames across an enterprise Active Directory domain. What attack methodology is being employed? [Authentication Scenarios | Medium]

A) Password Spraying

B) Credential Stuffing

C) Rainbow Table Lookup

D) Shoulder Surfing

✓ **Correct Answer: Password Spraying**

Explanation: Testing a single common password against thousands of accounts evades individual account lockout thresholds.

Q58. An attacker breaches a public gaming forum, extracts email/password combinations, and immediately attempts those exact combinations against Gmail, PayPal, and Amazon. What attack is this? [Authentication Scenarios | Medium]

A) Credential Stuffing

B) Social Engineering

C) Man-in-the-Middle (MitM)

D) Denial of Service

✓ **Correct Answer: Credential Stuffing**

Explanation: Credential stuffing exploits user credential reuse across unrelated services using leaked databases.

Q59. What is a 'Pepper' in password storage architecture, and how does it differ from a 'Salt'? [Password Hashing Details | Hard]

A) A pepper is a secret cryptographic key stored separately from the database (e.g. in an HSM or app config) used in hashing; salts are stored in the database

B) A pepper is an unencrypted copy of the user's password sent to their email

C) A pepper is a random 8-bit character prepended to the username

D) A pepper replaces the need for hashing functions entirely

✓ **Correct Answer: A pepper is a secret cryptographic key stored separately from the database (e.g. in an HSM or app config) used in hashing; salts are stored in the database**

Explanation: While salts are public per-user values stored in the DB, a pepper is an application-wide secret key kept outside the database.

Q60. In modern password hashing libraries, what does the 'Work Factor' (or iteration count / cost parameter) control?
[Password Hashing Details | Hard]

A) The computational time and memory required to compute each hash, slowing down offline cracking hardware

B) The maximum length of characters a user is allowed to type

C) The frequency at which the database backs up password tables

D) The physical temperature of the server room processors

✓ Correct Answer: The computational time and memory required to compute each hash, slowing down offline cracking hardware
Explanation: The work factor allows administrators to increase hashing difficulty over time as hardware speeds improve.

Q61. Which biometric modality is generally recognized as having the lowest False Acceptance Rate (highest individual uniqueness and accuracy)? **[Biometrics Deep-Dive | Medium]**

A) Iris recognition

B) Voice recognition

C) Keystroke dynamics

D) Facial geometry recognition

✓ Correct Answer: Iris recognition
Explanation: The human iris possesses over 240 degrees of freedom of distinct biometric features, providing exceptionally low false match rates.

Q62. What type of attack involves presenting a fake biometric artifact (such as a 3D printed silicon finger or high-res photograph) to a biometric sensor? **[Biometrics Deep-Dive | Medium]**

A) Presentation Attack (or Spoofing attack)

B) Rainbow table attack

C) SYN flood attack

D) Buffer overflow attack

✓ Correct Answer: Presentation Attack (or Spoofing attack)
Explanation: Presentation attacks attempt to bypass biometric sensors using artificial replicas or recorded media.

Q63. What hardware/software defense is built into modern biometric sensors to counter presentation (spoofing) attacks? **[Biometrics Deep-Dive | Hard]**

A) Liveness Detection (e.g. pulse detection, eye blinking, thermal sensing, micro-texture analysis)

B) Increasing the password length to 20 characters

C) Encrypting the network cable with IPsec

D) Rebooting the biometric device after every scan

✓ Correct Answer: Liveness Detection (e.g. pulse detection, eye blinking, thermal sensing, micro-texture analysis)
Explanation: Liveness detection verifies that the biometric sample originates from a living human subject present at the sensor.

Q64. In biometric performance metrics, if System A has an Equal Error Rate (EER) of 0.1% and System B has an EER of 1.5%, which system is mathematically more accurate? **[Biometrics Deep-Dive | Hard]**

A) System A (a lower Equal Error Rate indicates superior overall discrimination accuracy)

B) System B (a higher EER indicates stronger security)

C) Both systems have identical accuracy because error rates are subjective

D) System B because it allows more users to authenticate per minute

✓ Correct Answer: System A (a lower Equal Error Rate indicates superior overall discrimination accuracy)
Explanation: A lower EER signifies a better receiver operating characteristic (ROC) curve with fewer total errors.

UNIT VI: FIREWALLS & INTRUSION DETECTION

Q65. Why are behavioral / invisible CAPTCHAs (such as reCAPTCHA v3) often preferred over traditional distorted text challenges? [CAPTCHA Deep-Dive | Medium]

A) They evaluate user risk seamlessly based on cursor movement and interaction history without disrupting human user experience

B) They completely eliminate the requirement for web servers

C) They store user passwords in cleartext for faster login

D) They force users to speak their passwords aloud

✓ Correct Answer: They evaluate user risk seamlessly based on cursor movement and interaction history without disrupting human user experience

Explanation: Behavioral CAPTCHAs calculate a risk score based on browser interactions, presenting friction only to high-risk automated requests.

Q66. Can CAPTCHA protect a web application against SQL Injection or Cross-Site Scripting (XSS) vulnerabilities? [CAPTCHA Deep-Dive | Medium]

A) No, CAPTCHA only prevents automated request volume; it does not sanitize malicious inputs or fix code vulnerabilities

B) Yes, CAPTCHA automatically encrypts SQL databases

C) Yes, solving a CAPTCHA cleans all malicious JavaScript code

D) Only if the CAPTCHA is configured with 256-bit encryption

✓ Correct Answer: No, CAPTCHA only prevents automated request volume; it does not sanitize malicious inputs or fix code vulnerabilities

Explanation: CAPTCHA is an anti-automation rate-limiting tool, not an input validation or application vulnerability firewall.

Q67. In a standard packet-filtering firewall rule table, in what order are the filtering rules evaluated? [Firewall Rules & Architecture | Medium]

A) Top-down sequentially; the first rule that matches the packet is applied and evaluation stops

B) Randomly across all rules simultaneously

C) Bottom-up from lowest rule to top rule

D) Alphabetically according to the rule name

✓ Correct Answer: Top-down sequentially; the first rule that matches the packet is applied and evaluation stops

Explanation: Firewall rules are evaluated sequentially in order; once a packet matches a rule's criteria, its action (Permit/Deny) is taken immediately.

Q68. What is a Demilitarized Zone (DMZ) in network firewall architecture? [Firewall Rules & Architecture | Hard]

A) A perimeter network segment that separates internal private corporate networks from untrusted public networks

B) A physical bomb shelter housing backup power generators

C) An unencrypted public Wi-Fi hotspot in a cafeteria

D) A subnetwork where all firewall rules are permanently disabled

✓ Correct Answer: A perimeter network segment that separates internal private corporate networks from untrusted public networks

Explanation: Public-facing servers (web, mail, DNS) are placed in a DMZ so that if compromised, the internal private LAN remains protected behind an inner firewall.

Q69. Which type of firewall can detect and block a user from exfiltrating sensitive data hidden inside an HTTP POST payload? [Firewall Classifications | Hard]

A) Application-Level Gateway (Proxy Firewall) or Next-Generation Firewall (NGFW)

B) Stateless Packet-Filtering Firewall

C) Circuit-Level Gateway

D) Layer 2 Ethernet Bridge

✓ Correct Answer: Application-Level Gateway (Proxy Firewall) or Next-Generation Firewall (NGFW)

Explanation: Only application-aware firewalls with deep packet inspection (DPI) can inspect the actual content inside application-layer payloads.

Q70. What is an egress filtering rule in enterprise firewall management? [Firewall Classifications | Hard]

A) A rule that monitors and restricts outbound traffic leaving the internal network destined for the Internet

B) A rule that allows all inbound traffic from any external IP

C) A rule that formats the router hard drive on power off

D) A rule that manages printer ink levels

✓ Correct Answer: A rule that monitors and restricts outbound traffic leaving the internal network destined for the Internet

Explanation: Egress filtering prevents compromised internal machines from connecting to external malware Command & Control (C2) servers or exfiltrating data.

Q71. What is a False Positive in Intrusion Detection System telemetry? [Intrusion Detection & Prevention | Medium]

A) An alert generated for benign, legitimate network traffic that was mistakenly classified as malicious

B) A malicious attack that occurred without generating any alert

C) A virus that infected a computer successfully

D) A network cable that became physically disconnected

✓ **Correct Answer: An alert generated for benign, legitimate network traffic that was mistakenly classified as malicious**

Explanation: False positives waste security analysts' time and can cause alert fatigue in Security Operations Centers (SOCs).

Q72. What is a False Negative in Intrusion Detection System telemetry? [Intrusion Detection & Prevention | Hard]

A) A genuine malicious attack that passed through the network undetected without triggering an alert

B) An alert generated for normal web browsing activity

C) A software update that installed without errors

D) An email that was sent successfully

✓ **Correct Answer: A genuine malicious attack that passed through the network undetected without triggering an alert**

Explanation: False negatives represent dangerous blind spots where an active intruder breaches security completely unnoticed.

Q73. In a high-security enterprise network, where should Network Intrusion Detection System (NIDS) sensors ideally be placed? [Intrusion Detection & Prevention | Medium]

A) At critical network choke points, DMZ interfaces, and immediately behind the perimeter firewall

B) Exclusively inside the power supply units of printers

C) Outside the building on public telephone poles

D) Only on client smartphones running on cellular data

✓ **Correct Answer: At critical network choke points, DMZ interfaces, and immediately behind the perimeter firewall**

Explanation: Placing NIDS sensors behind the perimeter firewall allows monitoring of traffic that bypassed initial perimeter filtering.

Q74. Which of the following is a primary feature of Host-based Intrusion Detection Systems (HIDS) that network-based NIDS cannot perform? [Intrusion Detection & Prevention | Hard]

A) Monitoring encrypted local process memory, OS system calls, and file integrity on the local file system

B) Inspecting unencrypted network packets on the backbone router

C) Filtering physical radio frequencies from Bluetooth devices

D) Assigning dynamic IP addresses via DHCP

✓ **Correct Answer: Monitoring encrypted local process memory, OS system calls, and file integrity on the local file system**

Explanation: Because network traffic is heavily encrypted (HTTPS/TLS), NIDS often cannot inspect payloads, whereas HIDS inspects data directly on the host.